

Statement of Applicability (SoA)

FinFlow Ltd — ISO/IEC 27001:2022

Prepared as part of an ISO 27001 readiness engagement | Sample Consulting Deliverable

1. Purpose

This Statement of Applicability (SoA) documents which ISO/IEC 27001:2022 Annex A controls apply to FinFlow Ltd, a 40-person B2B fintech SaaS provider, and records the current implementation status of each. FinFlow provides an invoicing and payments platform for SME customers and is pursuing ISO 27001 certification to meet enterprise customer due diligence requirements. This SoA reflects a representative sample of controls selected for this readiness assessment rather than the full 93-control Annex A set.

2. Company Context

FinFlow Ltd is a fully remote organisation with all infrastructure hosted on AWS. It processes and stores customer payment data and financial records on behalf of its SME clients, making confidentiality, integrity and availability of that data core to its risk profile. FinFlow has no owned physical premises, which is reflected in the applicability of physical security controls below.

3. Control Applicability

ID	Control	Applicable	Status	Justification / Notes
A.5.1	Policies for information security	Yes	Implemented	Board-approved Information Security Policy in place, reviewed annually.
A.5.7	Threat intelligence	Yes	Partial	Subscribed to vendor security advisories; no formal threat intel process yet.
A.5.9	Inventory of information and other associated assets	Yes	Implemented	Asset register maintained in IT asset management tool, reviewed quarterly.
A.5.15	Access control	Yes	Implemented	Role-based access control (RBAC) enforced across production systems.
A.5.19	Information security in supplier relationships	Yes	Partial	Key vendors (cloud hosting, payment processor) assessed; smaller vendors not yet formally reviewed.
A.5.23	Information security for use of cloud services	Yes	Implemented	AWS used exclusively; shared responsibility model documented and understood.
A.5.24	Information security incident management planning	Yes	Implemented	Incident Response Policy defines roles, escalation and reporting timelines.
A.5.30	ICT readiness for business continuity	Yes	Partial	Backup and recovery in place; full BCP/DR plan not yet tested end-to-end.
A.5.34	Privacy and protection of PII	Yes	Implemented	GDPR-aligned data protection practices; DPA in place with sub-processors.
A.6.1	Screening	Yes	Implemented	Background checks conducted for all new hires with access to production systems.
A.6.3	Information security awareness, education and training	Yes	Partial	Onboarding security training in place; annual refresher not yet formalised.
A.6.5	Responsibilities after termination or change of employment	Yes	Implemented	Offboarding checklist includes access revocation within 24 hours.
A.7.1	Physical security perimeter	No	N/A	Fully remote company; no physical office premises housing information assets.
A.7.4	Physical security monitoring	No	N/A	Not applicable - no owned physical premises; hosting is cloud-only (AWS).
A.8.1	User endpoint devices	Yes	Implemented	MDM enforced on all company-issued laptops; disk encryption mandatory.
A.8.2	Privileged access rights	Yes	Implemented	Privileged accounts require MFA and are reviewed quarterly.

ID	Control	Applicable	Status	Justification / Notes
A.8.5	Secure authentication	Yes	Implemented	MFA enforced for all staff on email, VPN and production access.
A.8.8	Management of technical vulnerabilities	Yes	Partial	Quarterly vulnerability scans run; formal patch SLA not yet documented.
A.8.9	Configuration management	Yes	Partial	Infrastructure-as-code used for core services; config baseline not fully documented.
A.8.12	Data leakage prevention	Yes	Partial	Email DLP rules in place; endpoint DLP not yet deployed.
A.8.16	Monitoring activities	Yes	Implemented	Centralised logging via CloudWatch; SIEM alerting configured for critical events.
A.8.20	Networks security	Yes	Implemented	VPC segmentation, security groups and WAF in place for production environment.
A.8.24	Use of cryptography	Yes	Implemented	TLS 1.2+ in transit, AES-256 at rest for customer payment data.
A.8.25	Secure development life cycle	Yes	Partial	Code review and CI/CD checks in place; formal SDLC policy not yet documented.
A.8.28	Secure coding	Yes	Partial	SAST tooling in CI pipeline; secure coding training not yet formalised for all devs.

4. Summary

Of the 25 controls reviewed, 23 are applicable to FinFlow's environment. 13 are fully implemented, 10 are partially implemented with clear remediation actions identified, and 2 are not applicable due to FinFlow's fully remote, cloud-only operating model. Priority remediation areas include formalising the vulnerability patch SLA (A.8.8), completing third-party vendor risk assessments (A.5.19), and testing the business continuity plan end-to-end (A.5.30).